

SECURITY AUDIT REPORT & DOSSIER

Evaluation Baseline: OWASP ASVS 4.0 · NIST SP 800-63B · CIS Controls v8

1. Project & Auditor Identification

Target Application:	ApexPay Core Payment & Customer Portal v3.2	System Type:	Financial Web Application & Cloud REST Microservices
Intern Auditor:	Alex Mercer (CYBER-INT-2026-884)	Faculty Reviewer:	Dr. Sarah Vance, CISSP
Host Organization:	Apex Cyber Defense Institute / FinTech Security Lab	Audit Date:	2026-10-08
Verification Hash:	SEC-CYBERINT2026884-QWXLECBNZXJJZXJB	Status:	DRAFT

2. Executive Summary & Assessment Scope

This audit assessment evaluates the target system against OWASP ASVS 4.0, NIST SP 800-63B, and CIS Controls. Several critical authentication and input validation hardening steps are required prior to production authorization.

3. Security Health & Posture Scorecard

BASELINE COMPLIANCE 69% (29 Assessed Controls)	CONTROLS PASSED 20 (Verified Satisfactory)	CRITICAL GAPS / FAILURES 4 (High Action Required)	HARDENING WARNINGS 5 (Remediation Advised)
---	---	--	---

4. Compliance Breakdown by Cybersecurity Domain

Cybersecurity Domain	Controls	Pass	Fail	Warn	Score	Audit Verdict
1. Authentication Concepts	7	5	1	1	79%	Needs Hardening
2. Input Validation	6	4	1	1	75%	Needs Hardening
3. Security Checks & Hardening	6	5	1	0	83%	Satisfactory
4. Logging & Monitoring	5	3	1	1	70%	Needs Hardening
5. Security Awareness & Culture	5	3	0	2	80%	Satisfactory

5. Priority Identified Vulnerabilities & Required Actions

ID	Vulnerability Finding	Severity	Status	Auditor Observations	Engineering Action
AUTH-02	Multi-Factor Authentication (MFA / TOTP) Enforcement	CRITICAL	WARNIN G	MFA is implemented for billing admins but currently optional for standard customer accounts.	Enforce MFA by default across all privileged dashboards; provide backup recovery codes stored as hashed entries.
AUTH-05	JWT Token Security, Expiration & Algorithm Strictness	CRITICAL	FAIL	VULNERABILITY: Legacy endpoint <code>`/api/v1/session/verify`</code> accepted tokens when header alg was modified to "none"!	Explicitly pin algorithms parameter to <code>["HS256"]</code> or <code>["RS256"]</code> in <code>`jwt.verify()`</code> and disallow unsigned tokens.
INPUT-01	Parameterized Queries for SQL / NoSQL Injection Prevention	CRITICAL	FAIL	VULNERABILITY: Product search endpoint <code>`/api/catalog/search?q=`</code> concatenates raw query string into SQL LIKE clause.	Replace all string concatenations with parameterized placeholder parameters <code>`\${1}, \${2}`</code> or ORM query builders.
INPUT-02	Context-Aware Output Encoding & XSS Sanitization	HIGH	WARNIN G	Profile bio field sanitizes basic script tags but was susceptible to SVG onload vectors.	Use DOMPurify on client and sanitize-html on server with strict tag/attribute allowlists.
SEC-01	Content Security Policy (CSP) & Defense Headers	HIGH	FAIL	VULNERABILITY: Server is currently missing Content-Security-Policy and HSTS response headers in API responses!	Add Helmet middleware to Express configuration with hardened CSP directives.
LOG-02	PII, Passwords & Secret Redaction in Logs	CRITICAL	FAIL	VULNERABILITY: Debug logger in <code>`/api/auth/login`</code> was printing full <code>`req.body`</code> including <code>`password`</code> field!	Implement automatic regex-based masking middleware that redacts sensitive keys before serialization.
LOG-03	Centralized Append-Only Log Storage & Tamper Resistance	HIGH	WARNIN G	Logs are pushed to AWS CloudWatch, but retention policy is set to 30 days without WORM compliance lock.	Enable S3 Object Lock in Governance mode with 365-day minimum compliance retention.
AWR-01	Phishing Awareness Simulation & Training Curriculum	MEDIUM	WARNIN G	78% of staff completed annual training, but simulated phishing click rate is currently 14% (target < 5%).	Increase phishing simulation frequency to bi-monthly; introduce instant micro-learning feedback on click.
AWR-04	Social Engineering & Customer Support Verification Protocol	HIGH	WARNIN G	One support agent accepted verbal caller verification during test. Formal out-of-band PIN prompt is required.	Enforce mandatory automated in-app push verification prompt before agent can edit sensitive customer attributes.

6. Comprehensive 29-Control Audit Verification Matrix

Control ID	Requirement & Standard	Severity	Status	Assessor Findings & Evidence
AUTH-01	Password Entropy & Complexity Policy Enforcement [NIST SP 800-63B §5.1.1 / OWASP ASVS V2.1]	HIGH	PASS	Tested signup endpoint with a 14-character passphrase. System rejected weak dictionary words correctly.
AUTH-02	Multi-Factor Authentication (MFA / TOTP) Enforcement [OWASP ASVS V2.8 / CIS Control 6.3]	CRITICAL	WARNING	MFA is implemented for billing admins but currently optional for standard customer accounts.
AUTH-03	Brute Force Protection & Credential Stuffing Throttling [OWASP ASVS V2.2 / CWE-307]	HIGH	PASS	Tested burst of 7 attempts; 429 response triggered after attempt 5 with generic message "Invalid credentials".
AUTH-04	Cryptographic Password Hashing (Argon2id or bcrypt) [CWE-916 / OWASP Password Storage Cheat Sheet]	CRITICAL	PASS	Database confirms password column stores `argon2id\$v=19\$m=65536,t=3,p=4\$` hashes with unique salts.
AUTH-05	JWT Token Security, Expiration & Algorithm Strictness [RFC 7519 / OWASP ASVS V3.5 / CWE-347]	CRITICAL	FAIL	VULNERABILITY: Legacy endpoint `/api/v1/session/verify` accepted tokens when header alg was modified to "none"!
AUTH-06	Role-Based Access Control (RBAC) & Privileged Authorization [CIS Control 6.8 / OWASP ASVS V4.1]	HIGH	PASS	Tested role guards across API controller middlewares; server correctly denies customer tokens with 403.
AUTH-07	Secure Session Invalidation on Logout [OWASP ASVS V3.3 / CWE-613]	MEDIUM	PASS	Server maintains a Redis token revocation blocklist with TTL matching JWT expiration.
INPUT-01	Parameterized Queries for SQL / NoSQL Injection Prevention [OWASP Top 10 A03 / CWE-89]	CRITICAL	FAIL	VULNERABILITY: Product search endpoint `/api/catalog/search?q=` concatenates raw query string into SQL LIKE clause.
INPUT-02	Context-Aware Output Encoding & XSS Sanitization [OWASP Top 10 A03 / CWE-79 / ASVS V5.3]	HIGH	WARNING	Profile bio field sanitizes basic script tags but was susceptible to SVG onload vectors.
INPUT-03	Strict Schema & Allowlist Validation for Request Payloads [OWASP ASVS V5.1 / CWE-20]	MEDIUM	PASS	API uses Zod schema validation; extra keys are rejected with 422 Unprocessable Entity.
INPUT-04	File Upload MIME & Content-Type Verification [CWE-434 / OWASP File Upload Cheat Sheet]	HIGH	PASS	Avatar upload endpoint validates file magic headers via file-type library and writes to AWS S3 with generated UUID filenames.
INPUT-05	Server-Side Request Forgery (SSRF) Prevention [OWASP Top 10 A10 / CWE-918]	CRITICAL	PASS	Webhook registration validates destination against private IP ranges (RFC 1918) and cloud metadata CIDR blocks.
INPUT-06	Regular Expression Denial of Service (ReDoS) Defense [CWE-1333 / OWASP ASVS V5.1]	LOW	PASS	Tested regex expressions with safe-regex utility. All validation routines complete in <2ms.
SEC-01	Content Security Policy (CSP) & Defense Headers [OWASP Secure Headers Project / CIS Control 9.2]	HIGH	FAIL	VULNERABILITY: Server is currently missing Content-Security-Policy and HSTS response headers in API responses!
SEC-02	Cross-Origin Resource Sharing (CORS) Configuration [OWASP ASVS V14.4 / CWE-942]	CRITICAL	PASS	Tested origin reflection with curl; server strictly rejects origins outside https://*.apexpay.internal.
SEC-03	HTTPS / TLS 1.3 Strict Enforcement & Ciphers [CIS Control 3.10 / NIST SP 800-52r2]	HIGH	PASS	Reverse proxy listener enforces TLS 1.3 / TLS 1.2 with ECDHE ciphers and automatic HSTS redirects.
SEC-04	Sensitive Data at Rest Encryption (AES-256-GCM) [NIST SP 800-111 / PCI-DSS 3.4]	HIGH	PASS	Sensitive table columns store AES-GCM ciphertext encrypted with KMS envelope key.
SEC-05	Cookie Security Attributes (HttpOnly, Secure, SameSite) [OWASP ASVS V3.4 / CWE-1004]	HIGH	PASS	Tested session cookie flags: Set-Cookie: session_id=...; HttpOnly; Secure; SameSite=Strict; Path=/; Max-Age=3600.

Control ID	Requirement & Standard	Severity	Status	Assessor Findings & Evidence
SEC-06	API Rate Limiting & Denial-of-Service Mitigations [OWASP API Security Top 10 API4 / CIS 9.4]	MEDIUM	PASS	Global rate limiter enforces 100 req/min per IP on standard endpoints and 10 req/min on auth endpoints.
LOG-01	Security Event Audit Trail & Non-Repudiation [CIS Control 8.5 / NIST SP 800-92 / OWASP A09]	HIGH	PASS	Audit service logs JSON structured events with event_type, actor_id, target_id, ip_address, and timestamp.
LOG-02	PII, Passwords & Secret Redaction in Logs [CWE-532 / GDPR Art. 32 / PCI-DSS 3.4]	CRITICAL	FAIL	VULNERABILITY: Debug logger in `/api/auth/login` was printing full `req.body` including `password` field!
LOG-03	Centralized Append-Only Log Storage & Tamper Resistance [NIST SP 800-92 §4.2 / CIS Control 8.2]	HIGH	WARNING	Logs are pushed to AWS CloudWatch, but retention policy is set to 30 days without WORM compliance lock.
LOG-04	Automated Alerting Triggers for High-Risk Anomalies [OWASP A09 / CIS Control 8.11]	MEDIUM	PASS	Datadog metric monitor alerts the on-call engineer when 4xx error rate exceeds 5% of total traffic.
LOG-05	Time Synchronization via Network Time Protocol (NTP) [CIS Control 8.4 / ISO 27001 A.12.4.4]	LOW	PASS	Kubernetes nodes sync with AWS Time Sync Service (169.254.169.123); drift is < 2ms.
AWR-01	Phishing Awareness Simulation & Training Curriculum [CIS Control 14.1 / NIST SP 800-50]	MEDIUM	WARNING	78% of staff completed annual training, but simulated phishing click rate is currently 14% (target < 5%).
AWR-02	Incident Reporting Channel & 24/7 Security Escalation [NIST SP 800-61r2 / CIS Control 17.1]	HIGH	PASS	Tested "Report Phish" Outlook add-in; alert appeared in SOC Slack channel `#security-incidents` within 15 seconds.
AWR-03	Enterprise Password Manager Hygiene & 2FA Enforcement [CISA Guidance / CIS Control 14.4]	MEDIUM	PASS	100% of corporate workstations enrolled in 1Password Enterprise via Jamf/Intune MDM profile.
AWR-04	Social Engineering & Customer Support Verification Protocol [ISO 27001 A.7.2.2 / OWASP Security Culture]	HIGH	WARNING	One support agent accepted verbal caller verification during test. Formal out-of-band PIN prompt is required.
AWR-05	Clean Desk, Screen Lock & Removable Media Policy [CIS Control 14.7 / ISO 27001 A.11.2.9]	LOW	PASS	MDM enforces 5-minute inactivity lock, FileVault disk encryption, and blocks unauthorized USB storage.

7. Virtual Internship Sign-Off & Verification Attestation

OFFICIAL ACADEMIC & LABORATORY RECORD

CERTIFICATE OF APPLICATION SECURITY AUDIT

This document certifies that Alex Mercer (Student / Intern ID: CYBER-INT-2026-884)
has successfully conducted a full-scope security audit assessment for
ApexPay Core Payment & Customer Portal v3.2.

The assessment systematically audited all 29 required controls covering Authentication Concepts,
Input Validation, Defensive Security Checks, Logging & Monitoring, and Security Awareness
in strict compliance with OWASP ASVS 4.0 and NIST SP 800-63B standards.

CRYPTOGRAPHIC AUDIT SEAL: SEC-CYBERINT2026884-QWXLECBNZXJJZXJB

Alex Mercer
Intern Security Auditor Signature

Dr. Sarah Vance, CISSP
Faculty / Mentor Reviewer (CISSP)